

Documentación Técnica — Entrega 2

Proyecto: UTNotasApp

Grupo: 10 · DAM 2026

Integrantes: Andrada Santiago · Barbé Dante · Diez Nicolás · Soler Tomás

Fecha de entrega: 9 de junio de 2026

1. Autenticación y Autorización

1.1 Estrategia JWT

Los tokens se generan al hacer login (email/contraseña o Google OAuth) con una expiración de **7 días**. Se transmiten de dos formas según el cliente:

- **Cookie HttpOnly** (**token**): para clientes web. El flag **httpOnly** previene acceso desde JavaScript, mitigando XSS.
- **Bearer token** en header **Authorization**: para clientes nativos (React Native / Expo Go), que no soportan cookies de la misma forma.

El middleware **auth.middleware.ts** verifica el token en ambos canales en el siguiente orden: primero el header **Authorization**, luego la cookie.

1.2 Autorización basada en atributos (ABAC)

Se implementó control de acceso por atributos para recursos propios:

- **Usuarios:** **PATCH** **/api/users/:id** y **DELETE** **/api/users/:id** verifican que el **id** del JWT coincida con el **:id** del parámetro de ruta, **o** que el usuario tenga rol **ADMIN**.
- **Materiales:** **PATCH** **/api/materials/:id** y **DELETE** **/api/materials/:id** verifican que el **userId** del material en la base de datos coincida con el **id** del JWT, **o** que el rol sea **ADMIN**.

Si la verificación falla se responde con **403 Forbidden**.

1.3 Google OAuth

Flujo implementado en **google-auth.service.ts**:

1. El cliente envía el **idToken** de Google al endpoint **POST** **/api/auth/google**.
2. El backend verifica el token contra la API de Google usando **google-auth-library**.
3. Se extrae el **email** del payload verificado.
4. Si el email ya existe en la base de datos → se hace login y se genera un JWT.
5. Si el email no existe → se crea una cuenta nueva (sin contraseña en bcrypt, ya que la autenticación es delegada a Google).
6. Se devuelve el JWT + datos del usuario.

1.4 Protección de contraseñas

- Las contraseñas se hashean con **bcryptjs** (salt rounds: 10) antes de almacenarse.

- En las operaciones que requieren confirmación de contraseña (`PATCH /users/:id` y `DELETE /users/:id`), el backend usa `bcrypt.compare()` para verificar.
- Se implementó protección contra timing attacks en el login: siempre se ejecuta `bcrypt.compare()` aunque el usuario no exista (con un hash dummy), para que el tiempo de respuesta no revele si el email está registrado.

2. API / Backend

2.1 Nuevos endpoints en E2

`PATCH /api/users/:id`

Actualiza los datos del perfil del usuario.

Campo	Tipo	Descripción
<code>name</code>	string	Nombre (opcional)
<code>surname</code>	string	Apellido (opcional)
<code>username</code>	string	Nombre de usuario (opcional)
<code>password</code>	string	Nueva contraseña (opcional)
<code>currentPassword</code>	string	Requerida para confirmar el cambio

- Requiere token JWT válido.
- Solo acepta los campos listados (field whitelisting para prevenir escalada de privilegios).
- Responde con el usuario actualizado (sin contraseña).

`DELETE /api/users/:id`

Elimina la cuenta del usuario.

Campo	Tipo	Descripción
<code>password</code>	string	Requerida para confirmar

- Requiere token JWT válido.
- Verifica la contraseña antes de eliminar.
- Al eliminar, invalida la cookie del token.

`POST /api/auth/google`

Login o registro con Google OAuth.

Campo	Tipo	Descripción
<code>idToken</code>	string	Token de identidad de Google

- No requiere autenticación previa.

- Devuelve JWT + usuario.

2.2 Endpoints de E1 (sin cambios de interfaz)

Método	Ruta	Descripción
POST	/api/auth/login	Login email/contraseña
POST	/api/auth/logout	Cierre de sesión
GET	/api/auth/me	Usuario autenticado
POST	/api/users/register	Registro
GET	/api/users/:id	Perfil público
GET	/api/materials	Listar materiales (con filtros y paginación)
GET	/api/materials/:id	Detalle de material
POST	/api/materials	Subir material
PATCH	/api/materials/:id	Editar material (+ ownership check E2)
DELETE	/api/materials/:id	Eliminar material (+ ownership check E2)

2.3 Cambio en Prisma schema

Se hizo `careerId` opcional en el modelo `User`:

```
careerId Int? // Opcional hasta E3 (tabla Carrera sin seed en dev)
```

Esto permite el registro sin seleccionar carrera mientras las tablas de carreras/materias no están cargadas con datos de producción.

3. Decisiones de Refactoring

3.1 `AuthContext` — métodos nuevos

Se expandió `AuthContext.tsx` con dos métodos adicionales:

- `updateProfile(data)`: llama a `PATCH /api/users/:id` con el id del usuario en sesión. Actualiza el estado local del usuario si la operación es exitosa.
- `deleteAccount(password)`: llama a `DELETE /api/users/:id` con la contraseña de confirmación. Limpia el estado de sesión y redirige al login.

3.2 `navigateAfterAuth.ts` — extracción de lógica de navegación

La lógica de redirección post-autenticación se extrajo a una utilidad independiente para evitar duplicación entre el flujo de login por email y el flujo de Google OAuth.

3.3 `useMaterial` hook — `isOwner`

El hook `useMaterial.ts` ahora expone el booleano `isOwner`, calculado comparando `material.userId` con el `id` del usuario en sesión. `MaterialDetailScreen` usa este valor para mostrar u ocultar los botones de editar y eliminar.

3.4 `MaterialDetailScreen` — botones condicionales

```
{isOwner && (  
  <>  
    <IconButton icon="pencil" onPress={handleEdit} />  
    <IconButton icon="trash" onPress={handleDelete} />  
  </>  
)}
```

4. Seguridad

Medida	Implementación
Hash de contraseñas	bcryptjs, salt rounds 10
JWT HttpOnly cookie	flag <code>httpOnly: true, sameSite: 'strict'</code>
Validación de entrada	Zod en todos los endpoints
Field whitelisting	Solo se permiten campos explícitamente listados en updates
Ownership check	Middleware ABAC en recursos de usuario y material
Protección timing attack	bcrypt.compare() siempre ejecutado en login
Google token verification	Verificado con <code>google-auth-library</code> contra API de Google
CAPTCHA	Stub preparado (<code>recaptcha.middleware.ts</code>), deshabilitado (<code>CAPTCHA_ENABLED=false</code>) para E3

5. Estructura de carpetas (actualizada E2)

```
UTNotasApp/  
├── frontend/src/  
│   ├── features/  
│   │   ├── auth/  
│   │   │   ├── AuthContext.tsx          ← updateProfile, deleteAccount (nuevo E2)  
│   │   │   └── screens/ProfileScreen.tsx ← editar perfil, modal eliminar cuenta  
│   │   (nuevo E2)  
│   │   └── materials/  
│   │       ├── hooks/useMaterial.ts      ← isOwner (nuevo E2)  
│   │       └── screens/MaterialDetailScreen.tsx ← botones condicionales (nuevo E2)
```

```

├── utils/
│   └── navigateAfterAuth.ts      ← extraído en E2
└── backend/src/
    ├── routes/
    │   ├── user.routes.ts      ← PATCH y DELETE /users/:id (nuevo E2)
    │   └── auth.routes.ts      ← POST /auth/google (nuevo E2)
    ├── services/
    │   ├── user.service.ts     ← updateUser, deleteUser (nuevo E2)
    │   └── google-auth.service.ts ← verifyGoogleToken (nuevo E2)
    └── prisma/schema.prisma    ← careerId opcional (modificado E2)

```

6. Deuda técnica documentada

Item	Estado	Modelo DB	Plan E3
Votación (upvote/downvote)	Pendiente	Calificacion	Endpoints + UI de votos
Favoritos	Pendiente	Favorito	Endpoints + UI de favoritos
Reportes de materiales	Pendiente	Reporte	Endpoints + UI de reportes
Sistema de puntos	Pendiente	Punto	Lógica de puntos por votos y subidas
Foto de perfil	Pendiente	Campo profilePicture en User	Upload a almacenamiento (S3 o similar)
reCAPTCHA / hCaptcha	Stub preparado	—	Activar con CAPTCHA_ENABLED=true
Verificación de email	Pendiente	—	Flujo de verificación al registrarse
Recuperación de contraseña	Pendiente	—	Flujo de reset por email
Moderación ADMIN	Pendiente	Rol ADMIN en User	Dashboard de administración

7. Plan para Entrega 3

- Votación:** implementar `POST /api/materials/:id/votar` y `DELETE /api/materials/:id/votar`, actualizar `Punto` al votar, mostrar botones de voto en `MaterialDetailScreen`.
- Favoritos:** implementar `POST /api/materials/:id/favorito` y `DELETE /api/materials/:id/favorito`, pantalla o sección "Mis favoritos" en el perfil.
- Puntos / Gamificación:** calcular y mostrar puntos acumulados del usuario en el perfil.
- Reportes:** botón "Reportar material" en detalle, formulario con `MotivoReporte`.
- Foto de perfil:** selector de imagen + upload a almacenamiento externo.
- Panel ADMIN:** lista de reportes pendientes, posibilidad de eliminar materiales o usuarios.
- Activar reCAPTCHA** en registro y login.